
ĐẠI HỌC QUỐC GIA TP. HỒ CHÍ MINH
TRƯỜNG ĐẠI HỌC CÔNG NGHỆ THÔNG TIN
KHOA MẠNG MÁY TÍNH VÀ TRUYỀN THÔNG



BÁO CÁO THỰC TẬP DOANH NGHIỆP

Công ty: Trách nhiệm hữu hạn
An Toàn Thông Tin CMC

Người hướng dẫn tại công ty:	Trần Nhật Minh
Giáo viên hướng dẫn:	ThS. Đỗ Hoàng Hiến
Sinh viên thực hiện:	Lê Huy Hùng
Mã số sinh viên:	21520888
Lớp:	ATCL2021

TP. HỒ CHÍ MINH, tháng 6 năm 2023

**ĐẠI HỌC QUỐC GIA TP. HỒ CHÍ MINH
TRƯỜNG ĐẠI HỌC CÔNG NGHỆ THÔNG TIN
KHOA MẠNG MÁY TÍNH VÀ TRUYỀN THÔNG**



BÁO CÁO THỰC TẬP DOANH NGHIỆP

**Công ty: Trách nhiệm hữu hạn
An Toàn Thông Tin CMC**

Người hướng dẫn tại công ty:	Trần Nhật Minh
Giáo viên hướng dẫn:	ThS. Đỗ Hoàng Hiến
Sinh viên thực hiện:	Lê Huy Hùng
Mã số sinh viên:	21520888
Lớp:	ATCL2021

TP. HỒ CHÍ MINH, tháng 6 năm 2023

LỜI CẢM ƠN

Lời đầu tiên, tôi xin gửi lời cảm ơn sâu sắc đến trường Đại học Công nghệ Thông tin – Đại học Quốc gia Thành phố Hồ Chí Minh đã mở môn Thực tập tốt nghiệp và tạo điều kiện cho tôi có thể hoàn thành môn học này, để có được kinh nghiệm tốt hơn cho các môn chuyên ngành trong học kỳ chính. Tôi cũng xin chân thành cảm ơn quý thầy cô trong khoa Mạng máy tính và Truyền thông dữ liệu đã nhiệt tình, quan tâm, hỗ trợ tôi trong quá trình tìm vị trí thực tập phù hợp, đáp ứng mong muốn của bản thân. Đặc biệt, tôi xin cảm ơn sâu sắc thầy Đỗ Hoàng Hiền đã hỗ trợ tôi trong suốt thời gian thực tập vừa qua.

Tôi cũng xin bày tỏ lòng biết ơn đến Công ty CMC Cyber Security đã tạo điều kiện, môi trường thực tập cho tôi có cơ hội được trải nghiệm, được làm quen với công việc cụ thể, áp dụng được những kiến thức trên lớp vào môi trường thực tiễn, nâng cao hiểu biết của bản thân. Đặc biệt, tôi xin cảm ơn anh Trần Nhật Minh đã trực tiếp định hướng, hướng dẫn tôi trong quá trình thực hiện nhiệm vụ được giao với những kinh nghiệm và kiến thức quý báu. Tôi cũng xin cảm ơn các anh chị, các bạn đồng nghiệp đã hỗ trợ, những người đã giúp đỡ tôi khi gặp khó khăn, thắc mắc để đạt được kết quả tốt nhất.

Trong quá trình thực tập và hoàn thành báo cáo, tôi nhận thấy rằng kiến thức của bản thân còn có nhiều thiếu sót, dẫn đến việc không tránh khỏi mắc phải những sai sót không mong muốn. Mong nhận được sự chỉ bảo và đóng góp ý kiến từ quý thầy cô để có thể ngày càng hoàn thiện hơn về mặt kiến thức, tích lũy thêm kinh nghiệm và cải thiện bản thân trong quá trình tương lai.

Trân trọng.

TP. Hồ Chí Minh, tháng 6 năm 2023

NHẬN XÉT CỦA GIẢNG VIÊN HƯỚNG DẪN

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

MỤC LỤC

LỜI CẢM ON	3
NHẬN XÉT CỦA GIẢNG VIÊN HƯỚNG DẪN.....	4
DANH MỤC HÌNH ẢNH	7
PHẦN MỞ ĐẦU	9
CHƯƠNG 1: GIỚI THIỆU VỀ CÔNG TY	10
1.1. Giới thiệu chung	10
1.2. Lĩnh vực hoạt động.....	10
1.3. Những dịch vụ cung cấp liên quan đến An Toàn Thông Tin	12
1.4. Thông tin liên hệ	12
1.5. Môi trường làm việc.....	13
CHƯƠNG 2: GIỚI THIỆU CHƯƠNG TRÌNH THỰC TẬP	15
2.1. Tổng quan chương trình thực tập	15
2.2. Yêu cầu công việc.....	15
2.3. Thời gian thực tập	15
2.4. Quản lý công việc	15
CHƯƠNG 3: CÔNG VIỆC ĐƯỢC GIAO.....	17
3.1. Tìm hiểu hệ điều hành Windows.....	17
3.2. Mạng Linux và tăng cường bảo mật	17
3.3. Phân tích mạng thực tế.....	17
3.4. Giới thiệu kiến trúc mạng doanh nghiệp	17
3.5. Các công cụ và quy trình cho SOC.....	18
3.6. Nền tảng Arbor	18
CHƯƠNG 4: NỘI DUNG THỰC TẬP	19
4.1. CHI TIẾT NỘI DUNG THỰC TẬP	19

4.2.	Kết quả đạt được	32
4.3.	Định hướng sau thực tập.....	32
Tài liệu tham khảo		34

DANH MỤC HÌNH ẢNH

Hình 1: Trung tâm giám sát an toàn mạng CMC.....	10
Hình 2: Lễ trao chứng chỉ quốc tế.....	11
Hình 3: Phần mềm diệt Virus CMC INFOSEC	12
Hình 4: Tòa nhà CMC tại khu chế xuất Tân Thuận, Quận 7, TP HCM	13
Hình 5: Không gian làm việc.....	14
Hình 6: Bên trong tòa nhà.....	14
Hình 7: Hệ điều hành Windows.....	19
Hình 8: Hệ điều hành GNU/Linux.....	22
Hình 9: ModSecurity Core Rule Set	25
Hình 10: Shadow Daemon.....	25
Hình 11: OpenVPN.....	26
Hình 12: Pfsense.....	26
Hình 13: OPNsense	26
Hình 14: Kibana	27
Hình 15: Elasticsearch	28
Hình 16: Logstash	28
Hình 17: Filebeat.....	29
Hình 18: Snort	29
Hình 19: Suricata	30
Hình 20: Arbor Platform.....	31

DANH MỤC TỪ VIẾT TẮT

STT	Ký hiệu chữ viết tắt	Chữ viết đầy đủ
1	SOC	Security Operations Center
2	WAF	Web Application Firewall
3	IDS	Intrusion Detection System
4	IPS	Intrusion Prevention System
5	VPN	Virtual Private Network
6	DDoS	Distributed Denial of Service
7	API	Application Programming Interface
8	IPC	Inter-Process Communication
9	SIEM	Security Information & Event Management
10	EDR	Endpoint Detection and Response
11	SOAR	Security Orchestration, Automation & Response
12	ELK	Elasticsearch, Logstash & Kibana

PHẦN MỞ ĐẦU

Thực tập sinh những kiến thức hữu ích và một môi trường thực tiễn trong quá trình thực tập tại công ty trách nhiệm hữu hạn An toàn thông tin CMC, điều đó đã cung cấp cho thực tập sinh có góc nhìn rõ hơn về ngành an toàn thông tin và giúp cho việc áp dụng những kiến thức học tại trường lớp trở nên trực quan và thực tế hơn. Ngoài ra việc thực tập đã đặt nền móng cho việc định hình nên phương hướng học tập và phát triển bản thân trong tương lai, cũng như chỉ ra các vấn đề của bản thân để có thể cải thiện những hạn chế cần cải thiện.

Ngoài những lợi ích kể trên, việc thực tập tại công ty trách nhiệm hữu hạn An toàn thông tin CMC còn giúp bản thân hiểu về những công việc và kiến thức liên quan khi làm việc với vị trí của một chuyên viên giám sát hệ thống, bao gồm những kiến thức về hệ điều hành Windows, Linux, Network, DDoS Protection, SOC tools,... Thông qua đó giúp tôi bổ sung lại những kiến thức đã được học và có cơ hội được hiểu sâu hơn về chúng.

Nội dung đề tài gồm 3 phần sau:

Phần mở đầu

Phần nội dung

- Chương 1: Giới thiệu về công ty
- Chương 2: Giới thiệu chương trình thực tập
- Chương 3: Nội dung thực tập
- Chương 4: Các công việc được giao và thời gian thực hiện cụ thể

Phần kết luận

PHẦN NỘI DUNG

CHƯƠNG 1: GIỚI THIỆU VỀ CÔNG TY

1.1. Giới thiệu chung

CMC Cyber Security là công ty thành viên của Tập đoàn CMC, chính thức thành lập năm 2008, công ty công nghệ lớn thứ hai Việt Nam. CMC Cyber Security tự hào bao gồm một đội ngũ chuyên gia giỏi với nhiều bằng cấp quốc tế, hướng tới là sự hiện diện chiến lược của tập đoàn trong lĩnh vực nghiên cứu và phát triển các phần mềm và dịch vụ an toàn thông tin.



Hình 1: Trung tâm giám sát an toàn mạng CMC

Là thành viên đầu tiên gia nhập Hiệp hội các Nhà nghiên cứu mã độc châu Á và là 1 trong các đơn vị ở Việt Nam nằm trong nhóm các nhà sản xuất phần mềm diệt virus của Microsoft trên thế giới cũng như các dịch vụ cung cấp đạt nhiều tiêu chí quốc tế.

1.2. Lĩnh vực hoạt động

CMC Cyber Security là công ty chuyên cung cấp các sản phẩm diệt virus cho cá nhân và các dịch vụ tư vấn/giải pháp về an ninh an toàn thông tin cho hệ thống của tổ chức/doanh nghiệp. Thế mạnh của CMC Cyber Security là công ty đang cung cấp một dải hợp đồng dịch vụ rất rộng, từ làm phần mềm, cung cấp dịch vụ chuyên nghiệp đến dịch vụ tư vấn tiêu chuẩn bảo mật quốc tế.



Hình 2: Lễ trao chứng chỉ quốc tế

Một số giải pháp mà CMC Cyber Security cung cấp cho các đối tác:

- Giải pháp phòng chống mã độc và quản trị tập trung (CMDD) - CMC malware detection and defence.
- Phần mềm diệt virus - CMC internet security.
- Giải pháp tường lửa bảo vệ website (WAF).
- Giải pháp phòng chống mã hóa dữ liệu (CMC CryptoSHIELD).
- Phần mềm giải pháp tự động đánh giá lỗ hổng bảo mật CMC (CMC Vulnerability Assessment platform).
- Phần mềm hệ thống quản lý và giám sát an ninh an toàn thông tin CMC (CMC Security Information & Event Management).

1.3. Những dịch vụ cung cấp liên quan đến An Toàn Thông Tin



Hình 3: Phần mềm diệt Virus CMC INFOSEC

- Dịch vụ giám sát - CMC SOC (SIEM - EDR - SOAR)
- Dịch vụ hỗ trợ xử lý sự cố - CMC Incident Response Service.
- Dịch vụ săn tìm mối đe dọa - CMC Threat Hunting Service.
- Dịch vụ CMC Threats Intelligence.
- Dịch vụ tư vấn, đánh giá và cấp chứng chỉ PCI-DSS.
- Dịch vụ rà soát đánh giá tấn công APT.
- Dịch vụ kiểm định an ninh hệ thống (CMC Security Audit).
- Dịch vụ tấn công kiểm thử lỗ hổng bảo mật (CMC Penetration Pentesting).
- Dịch vụ rà quét lỗ hổng bảo mật (Vulnerability Assessment).

1.4. Thông tin liên hệ

Công ty CMC Cyber Security.

Địa chỉ trụ sở chính: Tầng 15, Tòa nhà CMC, Số 11 - Đường Duy Tân, Q.Cầu Giấy, Hà Nội.

Địa chỉ nơi thực tập: QP9W+GFM, KCX, Đường số 19, Tân Thuận Đông, Quận 7, Thành phố Hồ Chí Minh.



Hình 4: Tòa nhà CMC tại khu chế xuất Tân Thuận, Quận 7, TP HCM

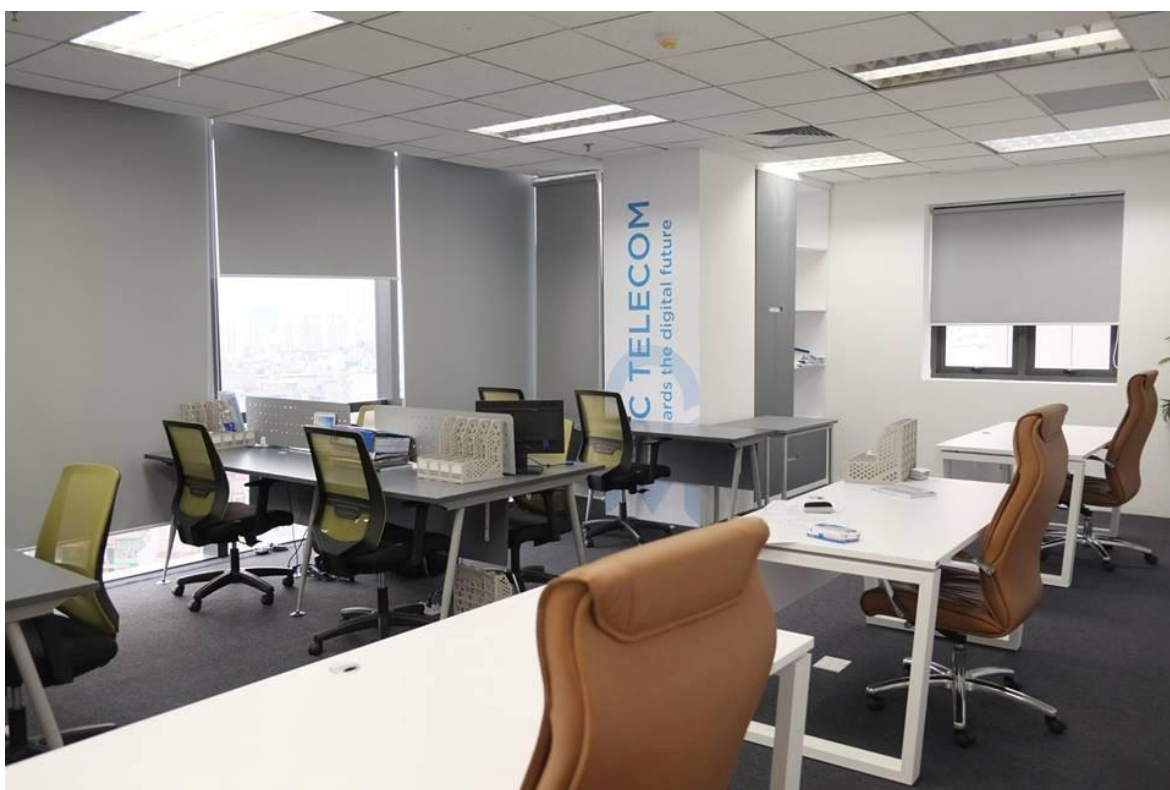
Website: <https://cmccybersecurity.com/>

1.5. Môi trường làm việc

- Làm việc 5 ngày/tuần (khoảng 44h/tuần), nghỉ thứ 7, Chủ Nhật.
- Môi trường làm việc trẻ, năng động, sáng tạo, công bằng, kỷ luật.
- Văn phòng xanh, đạt tiêu chuẩn quốc tế.
- Hỗ trợ ăn trưa, miễn phí đỗ xe tại tòa nhà.
- Tham gia gắn kết với tập thể, tổ chức với các hoạt động team building thú vị, các CLB chạy và đá bóng, esports,...các party liên hoan của công ty (sinh nhật, lễ Tết,...)
- Chế độ chăm sóc y tế đặc biệt cho nhân viên.



Hình 6: Bên trong tòa nhà



Hình 5: Không gian làm việc

CHƯƠNG 2: GIỚI THIỆU CHƯƠNG TRÌNH THỰC TẬP

2.1. Tổng quan chương trình thực tập

Trong suốt quá trình học tập và làm việc, sinh viên sẽ được đào tạo về các kiến thức cơ bản của ngành cũng như các kỹ năng cơ bản của một SOC analyst, bao gồm phân tích lưu lượng mạng, phát hiện và xử lý các sự cố bảo mật, đánh giá rủi ro, và triển khai các giải pháp bảo mật hiệu quả.

Sinh viên có cơ hội được tiếp cận các dự án thực tế cũng như được làm việc cùng với những đồng nghiệp có kinh nghiệm lâu trong ngành.

2.2. Yêu cầu công việc

- Đại học chuyên ngành Điện – điện tử, Điện tử viễn thông, Công nghệ thông tin, An Toàn thông tin.
- Có kiến thức tổng quan về mạng và bảo mật.
- Tinh thần trách nhiệm cao, thái độ tốt trong công việc.
- Tính đoàn kết, kỷ luật trong quá trình làm việc.
- Có khả năng đọc hiểu tiếng anh là một lợi thế.
- Làm việc trực tiếp tại văn phòng 4 buổi/tuần .

2.3. Thời gian thực tập

- Thời gian thực tập kéo dài từ ngày 05/09/2022 đến ngày 05/11/2022.
- Hình thức làm việc áp dụng mô hình kết hợp giữa làm việc từ xa và trực tiếp.
- Thời gian làm việc từ 8h00 đến 11h30 (sáng) và 1h đến 5h (chiều).
- Số buổi làm trực tiếp tại công ty linh hoạt.

2.4. Quản lý công việc

- Mô hình quản lý
 - Áp dụng mô hình làm việc Scrum để kiểm soát tiến độ dự án.
 - Trong tuần sẽ có những buổi báo cáo tiến độ, trao đổi những vấn đề tồn đọng trong tuần, cố định vào các buổi thứ 3 và thứ 6 hàng tuần.
 - Các buổi họp có thể thay đổi linh hoạt tùy theo lịch của các thành viên.
 - Một số buổi họp sẽ dùng để chia sẻ kinh nghiệm về các kỹ thuật, công nghệ giữa các thành viên trong nhóm.
- Công cụ quản lý
 - Sử dụng phần mềm nhắn tin Telegram để thảo luận, giải đáp các vấn đề trong công việc giữa các thành viên nội bộ cũng như để giao những công việc mới trong các dự án.

- Sử dụng một số kênh giao tiếp Zalo, Gmail để hỗ trợ khách hàng, đối tác trong quá trình tư vấn hoặc hỗ trợ giải pháp.
- Sử dụng các phần mềm quản lý tối ưu như Notion, Trello để ghi lại ghi chú cho công việc nhóm cũng như cập nhật tiến độ dự án, nhằm đảm bảo tiến độ cũng cho các thành viên trong nhóm biết được những đầu mục công việc cần phải làm.

CHƯƠNG 3: CÔNG VIỆC ĐƯỢC GIAO

3.1. Tìm hiểu hệ điều hành Windows

Thời gian: Từ ngày 1/5/2023 đến ngày 7/5/2023.

Nội dung: Tìm hiểu nội dung và thực hiện các bài thực hành liên quan trong sách Windows Internal bao gồm:

- Các khái niệm và công cụ.
- Bảo vệ hệ điều hành.
- Quản lý, chẩn đoán, và theo dõi.
- Mạng máy tính.

Kết quả: Hoàn thành tìm hiểu, ghi chú, và thuyết trình nội dung và triển khai những gì đã tìm hiểu được trong sách.

3.2. Mạng Linux và tăng cường bảo mật

Thời gian: Từ ngày 8/5/2023 đến ngày 21/5/2023.

Nội dung: Tìm hiểu nội dung và thực hiện các bài thực hành liên quan trong sách Master Linux Security and Hardening.

Kết quả: Hoàn thành tìm hiểu, ghi chú, và thuyết trình nội dung đã tìm hiểu được. Triển khai được những bài thực hành và các bài thực hành khác liên quan.

3.3. Phân tích mạng thực tế

Thời gian: Từ ngày 22/5/2023 đến ngày 27/5/2023.

Nội dung: Tìm hiểu nội dung và thực hiện các bài thực hành liên quan trong sách Practical Packet Analysis, Using Wireshark to Solve Real-World Network Problems.

Kết quả: Hoàn thành tìm hiểu, ghi chú, và thuyết trình nội dung về những gì đã tìm hiểu được. Triển khai các bài thực hành có trong sách và các bài khác liên quan bên ngoài.

3.4. Giới thiệu kiến trúc mạng doanh nghiệp

Thời gian: Từ ngày 28/5/2023 đến ngày 3/6/2023.

Nội dung: Tìm hiểu nội dung và thực hiện các bài thực hành liên quan trong sách Defensive Security Handbook: Best Practices for Securing Infrastructure

Kết quả: Hoàn thành tìm hiểu, ghi chú, và thuyết trình nội dung về những gì đã tìm hiểu được. Triển khai các bài thực hành có trong sách và các bài khác liên quan bên ngoài.

3.5. Các công cụ và quy trình cho SOC

Thời gian: Từ ngày 4/6/2023 đến ngày 17/6/2023.

Nội dung: Tìm hiểu và triển khai

- DDoS Prevention
- IDS/IPS
- WAF
- Firewall
- VPN

Kết quả: Thực hiện các buổi workshop nói về những nội dung trên bao gồm thuyết trình nội dung, trình bày các môi trường triển khai cũng như các triển khai những giải pháp bảo vệ trước các loại tấn công.

3.6. Nền tảng Arbor

Thời gian: Từ ngày 18/6/2023 đến ngày 30/6/2023.

Nội dung: Tìm hiểu tài liệu, các sách hướng dẫn, tài liệu liên quan về nội dung:

- Arbor Edge Defense User Guide.
- Defending Against DDoS Attacks using NETSCOUT Arbor Edge Defense.
- Sightline DDoS Mitigation.

Kết quả: Hiểu được cách sử dụng cho từng trường hợp cũng như các cài đặt trong việc thiết lập cài đặt khi xử lý các sự cố DDoS.

CHƯƠNG 4: NỘI DUNG THỰC TẬP

4.1. CHI TIẾT NỘI DUNG THỰC TẬP

4.1.1. Hệ điều hành Windows



Hình 7: Hệ điều hành Windows

- Yêu cầu:

Nắm được kiến trúc của hệ điều hành Windows bao gồm:

- Các khái niệm, thiết kế và công cụ căn bản được sử dụng trong hệ thống Windows đặc biệt là những công cụ quản lý tác vụ.
- Các giải pháp, kiến trúc bảo mật trên hệ thống Windows nhằm bảo vệ người dung trước các cuộc tấn công mạng cũng như những rủi ro từ các phần mềm độc hại.
- Kiến trúc mạng an toàn cho Windows và mô hình mạng căn bản.

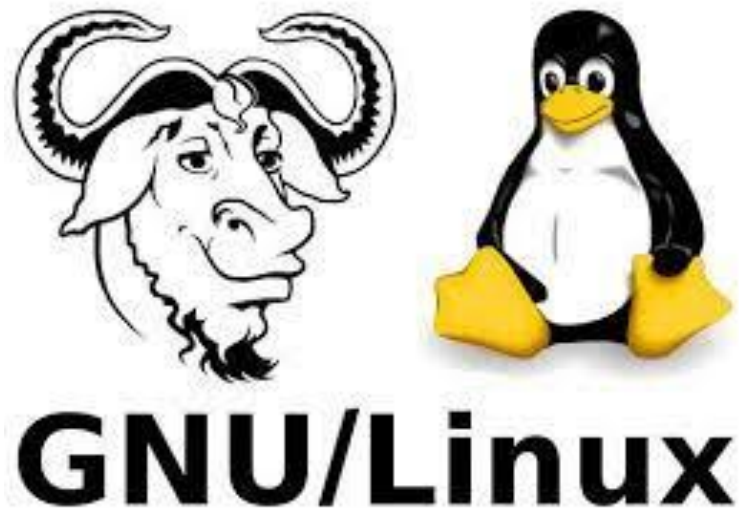
- Giải pháp:

- Tìm hiểu những kiến thức về những thành phần cấu tạo của hệ điều hành Windows được sử dụng nhiều và có liên quan tới vấn đề bảo mật của máy tính chạy hệ điều hành bao gồm:
 - Các chức năng sử dụng Windows API – nhằm tạo ra những ứng dụng lấy thông tin, hoặc chỉnh sửa các chương trình liên quan tới Windows.
 - Dịch vụ hệ thống – những dịch vụ hoặc những ứng dụng điều khiển được sử dụng để khởi chạy và quản lý các hành động của hệ điều hành.
 - Những chức năng được hỗ trợ ở chế độ Kernel.

- Những dịch vụ được Windows sử dụng và chạy ngầm.
- Dynamic link libraries (DLLs) – hiểu được những ứng dụng sử dụng các DLL và ý nghĩa.
- Windows process, threads, jobs – các cơ chế quản lý ứng dụng của hệ điều hành.
- Hypervisor – hiểu được cách Windows quản lý, tạo các máy, môi trường ảo để chạy ứng dụng.
- Firmware – hiểu được cách Windows liên kết các thành phần của máy tính lại.
- Registry – bộ quản lý thứ cấp để lưu thông tin, cài đặt quan trọng cho các chương trình.
- Windows Software Developments Kit (SDK) – làm quen với bộ công cụ phát triển phần mềm dành cho hệ điều hành Windows.
- Windows Driver Kit – làm quen bộ công cụ phát triển và triển khai drivers cho Windows.
- Windows Event – hiểu được cơ chế lưu trữ các sự kiện xảy ra trên máy tính Windows.
- Tìm hiểu được cách Windows bảo vệ người dùng bao gồm:
 - Influenced the design of Windows – tìm hiểu các tiêu chuẩn trong việc thiết kế hệ điều hành.
 - Virtualization-based security – hiểu được cơ chế chạy các chương trình trong môi trường các ly nhằm ngăn ngừa các đoạn mã độc hại ảnh hưởng lên máy tính.
 - WinObj Sysinternals tool – làm quen bộ công cụ theo dõi các vấn đề liên quan trình quản lý đối tượng.
 - The AuthZ API – thực hiện kiểm tra quyền truy cập có thể tùy chỉnh với hiệu suất và đơn giản hơn.
 - Account rights and privileges – hiểu được cách Windows phân quyền của các tài khoản.
 - Truy cập mã thông báo của quy trình và luồng.
 - Kiểm toán bảo mật thông tin.
 - AppContainers - đóng gói và chạy các ứng dụng Windows trên các môi trường đa dạng tại chỗ và trên đám mây.
 - Winlogon - thành phần chịu trách nhiệm xử lý chuỗi chú ý an toàn, tải hồ sơ người dùng khi đăng nhập
 - User Account Control and virtualization – giám sát các thay đổi của hệ thống và ngăn ngừa các ứng dụng không mong muốn khởi chạy.

- Exploit mitigations - chặn đứng các cuộc tấn công vào các ứng dụng phần mềm thường dùng mà nhà cung cấp chưa vá lỗi trên máy tính Windows.
- Nhận dạng ứng dụng.
- Tìm hiểu được các thành phần Windows Networking Software:
 - Windows Network APIs – hỗ trợ việc sử dụng mạng và Internet của ứng dụng máy tính.
 - Remote Procedure Call – là một giao thức giao tiếp phần mềm mà một chương trình có thể sử dụng để yêu cầu dịch vụ từ một chương trình nằm trong một máy tính khác trên mạng.
 - Web Access API – cung cấp chức năng giao tiếp mạng lỗi.
 - Named-pipes and mailslots – cơ chế truyền thông liên quá trình một chiều (IPC). Các ứng dụng có thể lưu trữ tin nhắn trong một mailslot.
 - NetBIOS – Network Basic Input/Output System, cung cấp các dịch vụ liên quan đến lớp phiên của mô hình OSI.
 - Hỗ trợ nhiều chuyển hướng.
 - Nhà cung cấp dịch vụ thay thế.
 - Không gian tên trên hệ thống tệp phân tán.
 - Tệp ngoại tuyến.
 - BranchCache.
- Triển khai và so sánh các thay đổi bảo mật Windows trước ứng phó trước các loại phần mềm độc hại. Sử dụng các phần mềm giám sát thay đổi:
 - Regshot: chụp lại trạng thái của registry Windows hỗ trợ so sánh trước và sau khi chạy
 - Windows Event: ghi lại các hoạt động, tác vụ trên Windows
 - Process Hacker: giám sát các tiến trình chạy của Windows

4.1.2. Hệ điều hành GNU/Linux



Hình 8: Hệ điều hành GNU/Linux

- Yêu cầu:

Nắm được kiến trúc của hệ điều hành Linux bao gồm:

- Triển khai được hệ thống Linux an toàn.
- Hiểu được File and Directory Access Control (DAC).
- Các kỹ thuật tăng cường bảo mật nâng cao.

- Giải pháp:

- Tìm hiểu và làm quen những cách phân quyền cho từng người dùng cho từng tác vụ cụ thể và 1 số cách mã hóa dữ liệu căn bản:
 - sudo privileges.
 - sudo timer.
 - sudo policy file.
 - Pam_tally2 - được sử dụng để khóa và mở khóa ssh đăng nhập thất bại
 - GNU Privacy Guard (GPG) - mã hóa và ký dữ liệu và thông tin liên lạc của bạn; nó có một hệ thống quản lý khóa đa năng.
 - Linux Unified Key Setup (LUKS) – mã hóa dữ liệu ổ đĩa.
 - OpenSSL – bảo mật dữ liệu khi chia sẻ trong mạng.
- Làm quen và tìm hiểu các sử dụng các loại firewall phổ biến trên hệ thống Linux bao gồm:
 - FirewallD.

- Iptables.
- Ubuntu Firewall (UFW).
- Nftables.
- Tìm hiểu được các kỹ thuật sử dụng để tăng tính bảo mật cho Linux:
 - SELinux, Apparmor – hạn chế các quyền của các chương trình.
 - Tăng cường bảo mật Linux và quy trình cách ly.
 - Quét, kiểm tra, tăng cường bảo mật.
 - Ghi nhật ký và bảo mật nhật ký.
 - Quét lỗ hổng và phát hiện xâm nhập.
- Triển khai dựa trên kiến thức trên bao gồm triển khai tường lửa (Iptables, UFW) để định tuyến các gói tin trong một hệ thống mạng cơ bản cũng như xử lý các trường hợp tăng lưu lượng mạng bất thường.

4.1.3. Phân tích mạng máy tính

- Yêu cầu:

Các chủ đề về phân tích mạng máy tính, và các khái niệm mạng căn bản:

- Cơ bản về phân tích gói và mạng.
- Làm quen với Wireshark.
- Làm việc với các gói đã bắt.
- Các tính năng Wireshark nâng cao.
- Hiểu được các giao thức mạng cho các tầng OSI.
- Phân tích bảo mật gói tin mạng.
- Phân tích các gói tin mạng không dây.

- Giải pháp:

- Tìm hiểu và làm quen các cách thức phân tích mạng với Wireshark.
- Tìm hiểu được các tình huống có thể xảy ra khi phân tích mạng.
- Nghiên cứu dựa trên các tài liệu để hiểu rõ các cơ chế của mạng máy tính
- Tìm hiểu cách bước tiến hành phân tích lưu lượng mạng của các cuộc tấn công cơ bản.
- Tìm hiểu được cách các thiết bị trong mạng hoạt động và chia sẻ thông tin với nhau.
- Tiến hành phân tích một số mẫu lưu lượng bắt được của các cuộc tấn công cơ bản bằng cách triển khai các tình huống giả định.
- Nghiên cứu dựa trên các thông tin phân tích để đưa ra các đặc trưng hay những bất thường của mạng.

4.1.4. Kiến trúc mạng doanh nghiệp

- Yêu cầu:

Các khái niệm căn bản trong kiến trúc mạng doanh nghiệp

- Hiểu được các cách quản lý tài sản và tài liệu.
- Các chính sách bảo mật cho các dịch vụ, sản phẩm, ... ngoài ra các chính sách cho nội bộ các nhân viên của doanh nghiệp.
- Các tiêu chuẩn, quy định pháp lý quốc tế dành cho các sản phẩm liên quan tới triển khai phù hợp.
- Cách giáo dục cho người dùng để giảm thiểu các vụ tấn công mạng tới người dùng như lừa đảo.
- Hiểu được một số cách xử lý sự cố bao gồm các quy trình xử lý, triển khai các giải pháp bảo vệ.
- Khôi phục lại cơ sở vật chất, dữ liệu tại các trung tâm lưu trữ thông tin sau các thảm họa.
- Nắm được các tiêu chuẩn và bộ khung công nghiệp để phát triển ứng dụng.
- Các kỹ thuật nhằm đảm bảo an toàn cho tòa nhà, các trung tâm dữ liệu lớn, ... khỏi những tác nhân, rủi ro vật lý.

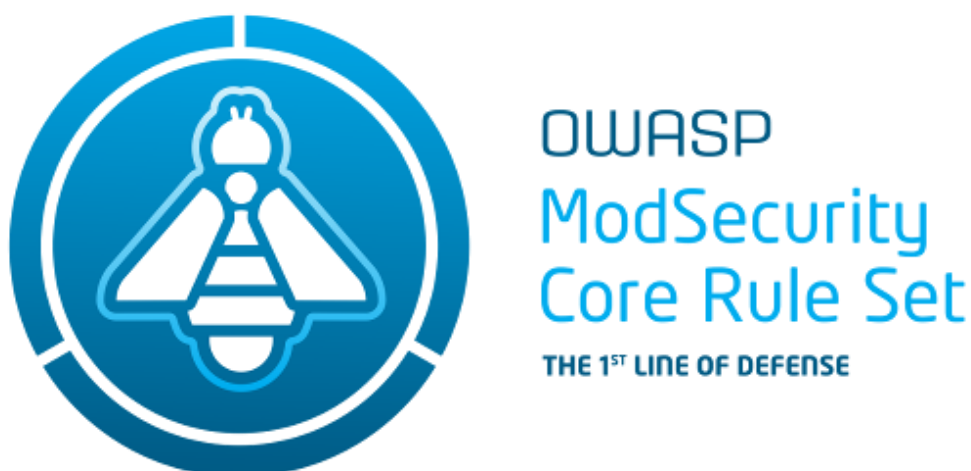
- Giải pháp:

- Tìm hiểu các hoạt động cơ bản của kiến trúc mạng doanh nghiệp.
- Làm quen các chính sách, quy định mà các ứng dụng cần đảm bảo khi triển khai.
- Tìm hiểu và làm quen các biện pháp nghiệp cụ thể nhằm đảm bảo an toàn thông tin của doanh nghiệp cũng như nghiệp vụ xử lý thông tin trong các sự cố cụ thể.
- Tham khảo các chính sách tại công ty thực tập nhằm đối chiếu với kiến thức đã tìm hiểu
- Đánh giá mức độ an toàn của các chính sách tìm hiểu được nhằm đưa ra đề xuất cải thiện

4.1.5. Các công cụ cho SOC

- Yêu cầu:

Nắm được kiến thức cơ bản và cách sử dụng các công cụ phổ biến cho SOC:



Hình 9: ModSecurity Core Rule Set

- WAF (Modsecurity, Shadow Daemon)
 - Hiểu các cơ chế bảo vệ ứng dụng của WAF tại tầng ứng dụng OSI.
 - Biết được WAF phòng chống các loại tấn công phổ biến mà các cách phòng chống khác khó xử lý toàn bộ trên các ứng dụng như xử lý đầu vào của người dùng.
 - Sử dụng WAF để làm màn lọc để loại bỏ các payload chứa nội dung độc hại và giảm tải áp lực cho các hệ thống phía sau như Firewall, IDS/IPS, ...



Hình 10: Shadow Daemon

- VPN (OpenVPN)
 - Tìm hiểu OpenVPN Access Server dùng để truy cập bảo mật tới các ứng dụng nội bộ cũng như mã hóa dữ liệu chia sẻ.
 - Làm quen với các loại tunnel (đường hầm mạng).
 - Hiểu các cách VPN mã hóa dữ liệu cho doanh nghiệp.



Hình 11: OpenVPN

- Firewall (pfsense, opensense)
 - Hiểu được cấu hình cơ bản pfsense, opensense.
 - Nắm được các cách hoạt động cũng như cách triển khai của pfsense, opensense cho mô hình mạng doanh nghiệp.
 - Hiểu được các tính năng cơ bản bao gồm thiết lập các quy tắc, định tuyến, triển khai các module kèm theo nhằm tăng cường tính an toàn cho hệ thống triển khai.



Hình 12: Pfsense



Hình 13: OPNsense

- SIEM (ELK stack)
 - Hiểu được cách cài đặt các agent nhằm mục đích thu thập thông tin.
 - Hiểu được các ứng dụng dựa trên hoạt động của các thành phần trong ELK stack:
 - Kibana - là một phần mềm bảng điều khiển trực quan hóa dữ liệu nguồn có sẵn cho Elasticsearch. Sử dụng để giám sát thông tin agent gửi về từ đó có thể xử lý sự cố kịp thời hoặc sử dụng các câu truy vấn để phân tích các cuộc tấn công.



Hình 14: Kibana

- Elasticsearch - cung cấp một bộ máy tìm kiếm dạng phân tán, có đầy đủ công cụ với một giao diện web HTTP có hỗ trợ dữ liệu JSON.



elasticsearch

Hình 15: Elasticsearch

- Logstash – là đường ống xử lý dữ liệu phía máy chủ nhập dữ liệu từ nhiều nguồn, biến đổi dữ liệu phù hợp và gửi tới Elasticsearch phân tích.



Hình 16: Logstash

- Filebeat – gửi logs từ agent tới Elasticsearch.



Hình 17: Filebeat

- IDS/IPS (snort, suricata)
 - Hiểu được cách bảo vệ hệ thống mạng với cái công cụ IDS/IPS.
 - Làm quen viết bộ quy tắc nhằm ngăn chặn hoặc cảnh báo cho từng loại tấn công cụ thể.
 - Hiểu được các mô hình mạng triển khai IDS/IPS phù hợp với từng trường hợp cụ thể.
 - Snort



Hình 18: Snort

- Suricata



Hình 19: Suricata

- Giải pháp:

- Tìm hiểu và triển khai được hệ thống phát hiện và ngăn ngừa xâm nhập Suricata và Snort để chặn các tấn công căn bản.
- Làm quen với các công cụ WAF nhằm xử lý các cuộc tấn công trên tầng ứng dụng.
- Sử dụng bộ công cụ ELK để giám sát các hoạt động trong mạng cũng như quản lý nhật ký mà các agent gửi tới từ đó sử dụng các chức năng lọc để phát hiện hành vi bất thường trong hệ thống mạng.
- Triển khai được VPN nhằm tăng cường bảo vệ dữ liệu chia sẻ và tạo kết nối nội bộ.
- Đánh giá hiệu suất mạng khi sử dụng các phần mềm bảo vệ IDS/IPS
- Phân tích mô hình mạng doanh nghiệp và theo yêu cầu dựa trên các yếu tố có sẵn để triển khai mô hình mạng tổng hợp
- Đánh giá hiệu suất và chi phí triển khai IDS/IPS so với các giải pháp khác
- Phân tích các trường hợp sử dụng VPN có gây ảnh hưởng tới công việc trong mạng.
- Nghiên cứu các mô hình, cấu hình sử dụng VPN cho từng yêu cầu, quy mô cụ thể.
- Đánh giá khả năng mã hóa dữ liệu, khả năng xử lý lưu lượng mạng lớn từ các cuộc tấn công khi triển khai các giải pháp an toàn.
- Tìm hiểu các sử dụng các bộ quy tắc và tự viết các quy tắc nhằm thực hiện những kiến thức tìm hiểu được.
- Đối chiếu và so sánh hiệu quả triển khai của WAF

4.1.6. Ứng phó tấn công DDoS



The Security Division of NETSCOUT

Hình 20: Arbor Platform

- Yêu cầu:

- Hiểu được các loại DDoS phổ thông:
 - Volumetric Attacks.
 - TCP State-Exhaustion Attacks.
 - Application Layer Attacks.
- Các biện pháp phòng ngừa cho một số trường hợp cơ bản.
- Một số mô hình triển khai và các trường hợp bảo vệ.
- Arbor DDoS Protection: Giải pháp phòng chống tấn công DDoS của NETSCOUT:
 - Arbor Edge Defense.
 - Arbor Sightline.

- Giải pháp:

- Tìm hiểu được dấu hiệu và cơ chế hoạt động của các loại tấn công DDoS.
- Làm quen với Arbor Edge Defense và tìm hiểu các cách triển khai để phòng tránh và giảm thiểu ảnh hưởng từ các tấn công DDoS.
- Tìm hiểu cách cài đặt cho từng trường hợp cụ thể.
- Tìm hiểu các cách ứng phó khi gặp sự cố liên quan DDoS.
- Đánh giá các cài đặt bao gồm có chặn được tấn công mong muốn, có chặn nhầm những mục tiêu cho phép,...

- Nghiên cứu các cách sử dụng Arbor kết hợp các giải pháp khác nhằm tăng cường tính bảo mật.

4.2. Kết quả đạt được

4.2.1. Các công nghệ đã triển khai

- Sử dụng Snort, Suricata để triển khai IDPS.
- Nắm được kiến thức cơ bản về hệ điều hành Linux, Windows.
- Sử dụng ModSecurity, Shadow Daemon để triển khai WAF.
- Sử dụng bộ công cụ ELK stack phục vụ việc giám sát traffic mạng.
- Sử dụng Arbor Platform phục vụ ngăn chặn tấn công DDoS.

4.2.2. Kỹ năng mềm

- Kỹ năng giao tiếp để có thể trao đổi, thảo luận công việc, ngoài ra kỹ năng này còn giúp làm quen với các đồng nghiệp, tạo bầu không khí vui vẻ.
- Kỹ năng làm việc nhóm để có thể chia công việc phù hợp theo khả năng, xử lý, tối ưu hiệu suất làm việc cũng như nhanh chóng nắm bắt thông tin.
- Kỹ năng thuyết trình để chia sẻ những kiến thức mình học được cũng như là cách nói chuyện dẫn dắt người nghe.
- Kỹ năng quản lý thời gian để sắp xếp thời gian hợp lý cho từng công việc nhỏ cụ thể, tính kỷ luật về giờ giấc trong quá trình thực tập.
- Kỹ năng giải quyết vấn đề để đưa ra những giải pháp cụ thể cho từng vấn đề cụ thể.
- Kỹ năng viết báo cáo, tương tác trình bày với người hướng dẫn bao gồm viết mail, nhắn tin nhằm chủ động liên hệ hỏi về công việc hoặc giao về công việc mới.

4.3. Định hướng sau thực tập

Sau 3 tháng được thực tập và có cơ hội thực hiện những công việc được giao, bản thân tôi đã thu được nhiều kết quả nhất định bao gồm kiến thức, và thành phẩm cũng như kỹ năng cần thiết dành cho công việc trong môi trường doanh nghiệp.

Công việc được thực tập phù hợp với năng lực, mong muốn của bản thân trong lĩnh vực an toàn thông tin, nên dự định trong tương lai của tôi là vẫn tiếp tục gắn bó với vị trí này nhằm học hỏi, trau dồi thêm kiến thức cũng như ổn định công việc sau khi tốt nghiệp.

Qua quá trình thực tập này mà bản thân tìm hiểu những công việc mới, những công nghệ mới, những kiến thức mà trước đó bản thân chưa được tiếp xúc hoặc chưa có nhiều cơ hội ứng dụng và điều đó mang đến cho tôi những trải nghiệm mới mẻ. Những kinh nghiệm dù ít ỏi mà tôi đã trau dồi được trong quá trình thực tập tại CMC Cyber Security sẽ giúp tôi phần nào và cũng là những bài học quý giá trong môi trường làm việc thực tế trong tương lai.

Tài liệu tham khảo

- Cisco. (2023, June). *Snort*. Retrieved from <https://www.snort.org/>
- Deciso. (2023, June). *OPNsense*. Retrieved from <https://opnsense.org/>
- Elastic. (2023, June). *ELK stack*. Retrieved from <https://www.elastic.co/what-is/elk-stack>
- Foundation, O. I. (2023, June). *Suricata*. Retrieved from <https://suricata.io/>
- Netgate. (2023, June). *pfsense*. Retrieved from <https://www.pfsense.org/>
- Netscout. (2023, June). *Arbor Edge Defense & Arbor Enterprise Manager*. Retrieved from <https://www.netscout.com/product/arbor-aed-aem>
- Netscout. (2023, June). *Arbor Sightline*. Retrieved from <https://www.netscout.com/product/arbor-sightline>
- OpenVPN. (2023, June). *OpenVPN*. Retrieved from <https://openvpn.net/>
- OWASP. (2023, June). *OWASP ModSecurity Core Rule Set*. Retrieved from <https://owasp.org/www-project-modsecurity-core-rule-set/>
- Security, C. C. (2023, June). Retrieved from <https://cmccybersecurity.com/>
- Zecure. (2023, June). *Shadow daemon*. Retrieved from <https://github.com/zecure/shadowd>